A

Report on

PRACTICAL SECURITY ASSESSMENT (TASK 9)

Submitted In Partial Fulfillment of the Requirements

for the

Cyber Security Internship (Week 4) (VAPT)

Internship Organization

CyArt Tech LLP

Submitted by

DIGVIJOY RANJAN

B.Tech in CSE (2303330109004)

Raj Kumar Goel Institute of Technology and Management, Ghaziabad

Submission Date: 10 April 2026

LIST OF FIGURES

CHAPTER NO.	TITLE	PAGE NO.
1	Figure 1 : Metasploit exploitation showing successful command shell session	4
2	Figure 2: Exploit chain execution	4
3	Figure 3: Burp suite api request interception	5
4	Figure 4: API token manipulation attack	5
5	Figure 5: Linpeas privilege escalation output	6
6	Figure 6 : SUID Binary Exploitation result	6
7	Figure 7: Responder SMB relay attack output	7
8	Figure 8: ARP Spoofing using ettercap	7
9	Figure 9: Wireshark captured network traffic	8
10	Figure 10: Metasploit Success	11

TABLE OF CONTENTS

CHAPTER NO.	TITLE	PAGE NO.
	LIST OF FIGURES	**i**
	TABLE OF CONTENTS	**ii**
1.	**INTRODUCTION**	
	1.1 PURPOSE OF THE REPORT	1
	1.2 PURPOSE OF THIS TASK	1
	1.3 TARGET INFORMATION	1
	1.4 OBJECTIVES	1
2.	**THEORETICAL KNOWLEDGE**	
	2.1 ADVANCED EXPLOIT TECHNIQUES	2
	2.2 API SECURITY TESTING	2
	2.3 PRVILAGE ESCALATION & PERSISTENCE	2-3
	2.4 NETWORK PROTOCOL	3
	2.5 MOBILE APPLICATION TESTING	3
	2.6 REPORT REMEDIATION	3
3.	**PRACTICAL IMPLEMENTATION**	
	3.1 ADVANCED EXPLOITATION LAB	4
	3.2 API SECURITY TESTING LAB	5
	3.3 PRIVILEGE ESCALATION LAB	6
	3.4 NETWORK ATTACK LAB	7
	3.5 MOBILE APPLICATION TESTING LAB	8
4.	**TOOLS USED**	**9**
5.	**RESULTS AND FINDINGS**	**10-11**
6.	**CAPSTONE PROJECT (FULL VAPT ENGAGEMENT)**	
	6.1 EXECUTIVE SUMMARY	12
	6.2 ATTACK TIMELINE	12
	6.3 KEY FINDINGS	12
	6.4 REMEDIATION PLAN	12
7.	**CONCLUSION AND REFERENCE**	
	5.1 CONCLUSION	13
	5.2 REFERENCE	13
8.	**APPENDIX**	**14-15**

1. INTRODUCTION

1.1 Purpose of the Report

The purpose of this report is to provide a detailed analysis of the Vulnerability Assessment and Penetration Testing (VAPT) activities conducted on selected systems and applications. The report aims to identify security weaknesses, demonstrate their impact, and provide remediation strategies to strengthen overall security posture.

1.2 Purpose of This Task

The scope of this assessment includes:

- Web Applications
- REST APIs
- Network Infrastructure
- Mobile Applications
- Authentication and Authorization mechanisms

Both black-box and gray-box testing methodologies were used during the assessment.

1.3 Target Information

The Penetration Testing Execution Standard (PTES) methodology was followed:

1. Pre-engagement Interactions
2. Intelligence Gathering (Reconnaissance)
3. Threat Modeling
4. Vulnerability Analysis
5. Exploitation
6. Post-Exploitation
7. Reporting

Each phase was carefully documented to ensure accuracy and reproducibility.

2. THEORETICAL KNOWLEDGE

2.1 Advanced Exploitation Techniques

Advanced exploitation techniques involve chaining multiple vulnerabilities to achieve deeper system access. Examples include:

- Exploit chaining (e.g., XSS + Session Hijacking)
- Bypassing authentication using logic flaws
- Exploiting misconfigured services
- Buffer overflow and memory corruption attacks

2.2 API Security Testing

API security testing focuses on:

- Broken Object Level Authorization (BOLA)
- Broken Authentication
- Excessive Data Exposure
- Lack of Rate Limiting
- Injection Attacks (SQL/Command Injection)

Testing includes manual inspection and automated scanning.

2.3 Privilege Escalation & Persistence

Privilege escalation involves gaining higher privileges after initial access:

- Vertical Privilege Escalation (User → Admin)
- Horizontal Privilege Escalation (User → Another User)

Persistence techniques include:

- Backdoor creation

- Scheduled tasks
- SSH key injection

2.4 Network Protocol Attacks

Privilege Common network attacks include:

- ARP Spoofing
- DNS Spoofing
- Man-in-the-Middle (MITM)
- Packet Sniffing

These attacks exploit weaknesses in communication protocols.

2.5 Mobile Application Penetration Testing

Privilege Mobile testing includes:

- Static Analysis (APK decompilation)
- Dynamic Analysis (Runtime behavior)
- Insecure Data Storage
- Weak Encryption
- Certificate Pinning bypass

2.6 Reporting & Remediation

A proper report includes:

- Vulnerability description
- Risk rating (CVSS)
- Proof of Concept (PoC)
- Impact analysis
- Remediation steps

3. PRACTICAL IMPLEMENTATION

3.1 Advanced Exploitation Lab

In this lab, multiple vulnerabilities were chained to gain system-level access. For example:

- XSS used to steal session cookies
- Session reuse for unauthorized login

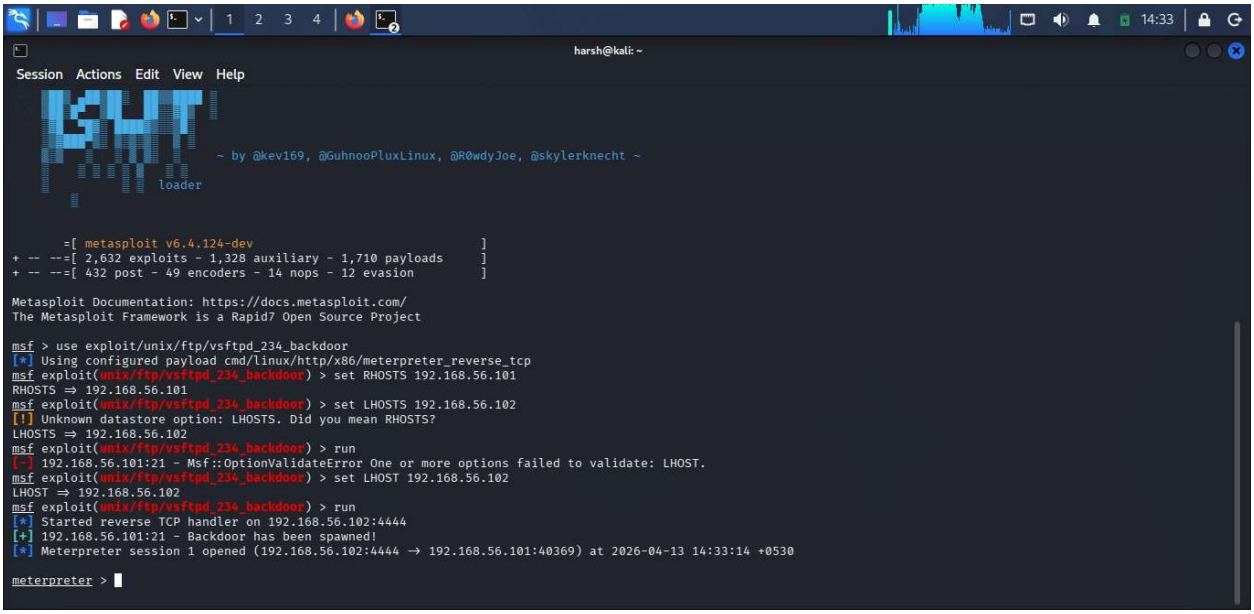

Figure 1: Metasploit exploitation showing successful command shell session

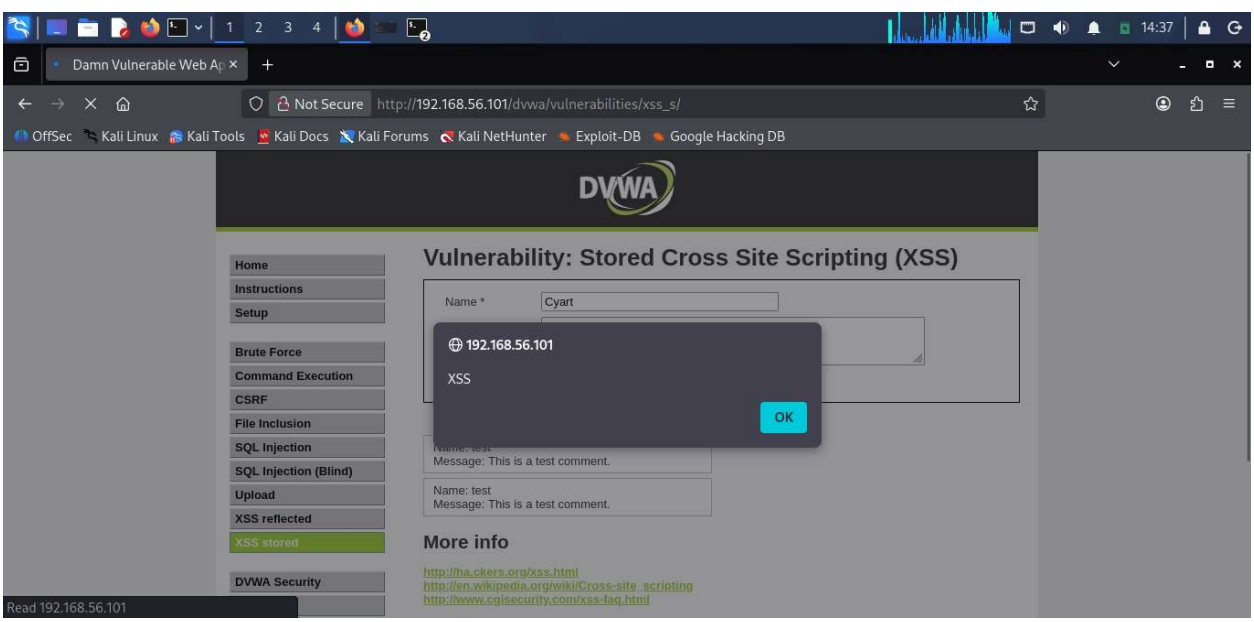

Figure 2: Exploit chain execution

3.2 API Security Testing Lab

APIs were tested using tools like Postman and Burp Suite. Vulnerabilities found:

- IDOR (Insecure Direct Object Reference)
- Missing authentication checks

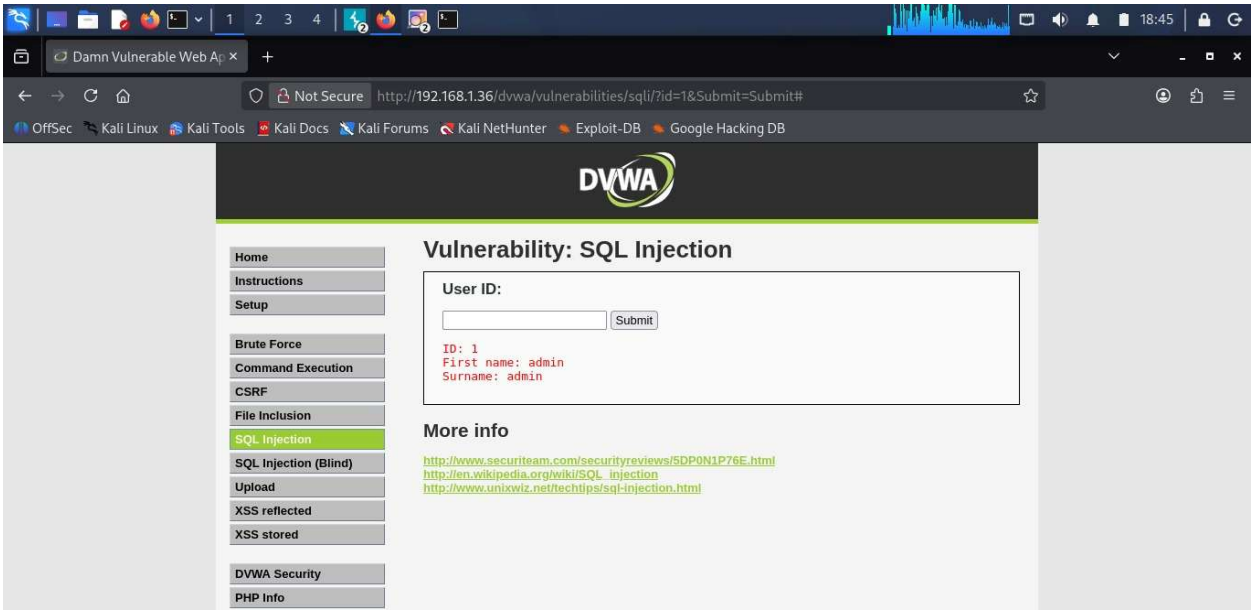

Figure 3: Burp suite api request interception

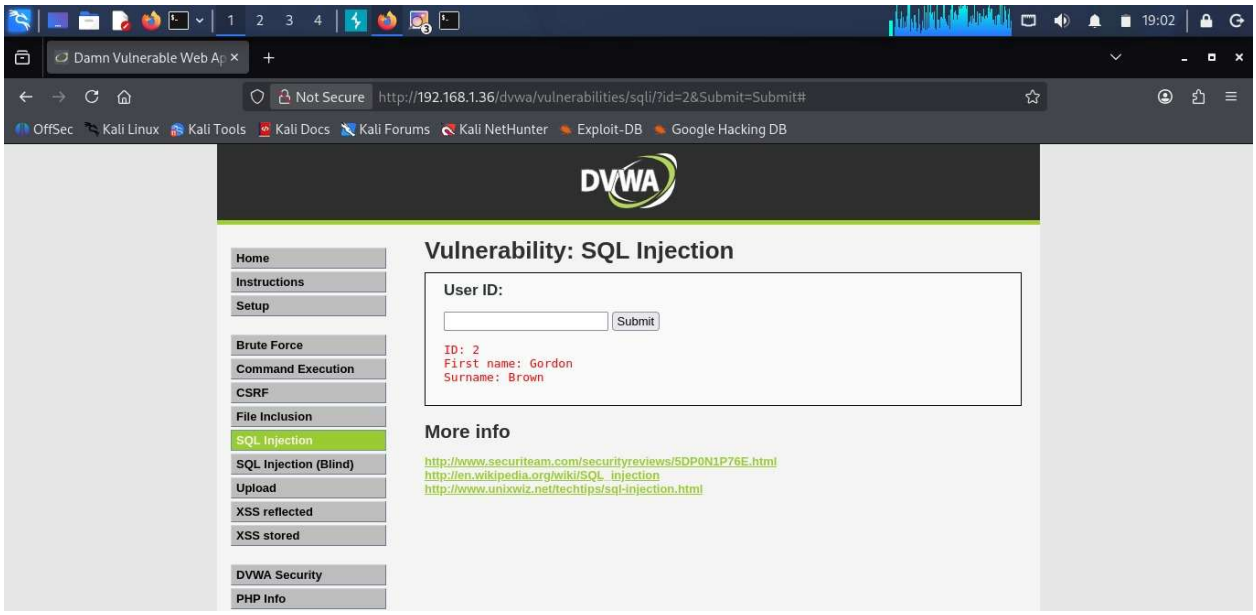

Figure 4: API token manipulation attack

3.3 Privilege Escalation Lab

Linux and Windows privilege escalation techniques were applied:

- Exploiting SUID binaries (Linux)
- Weak service permissions (Windows)

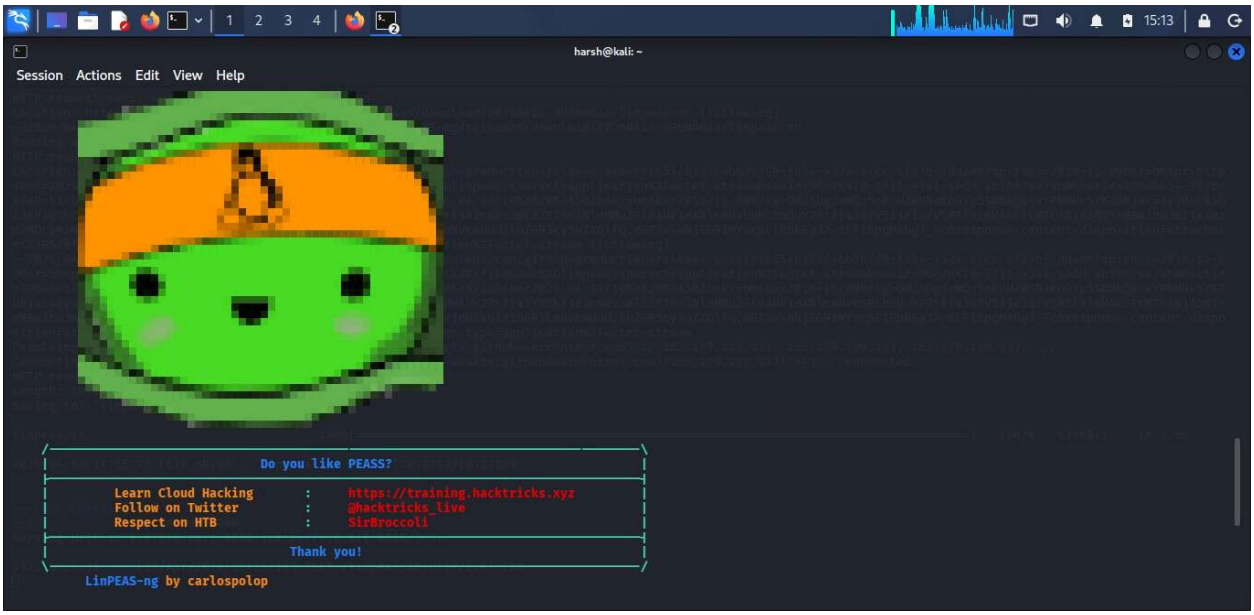

Figure 5: Linpeas privilege escalation output

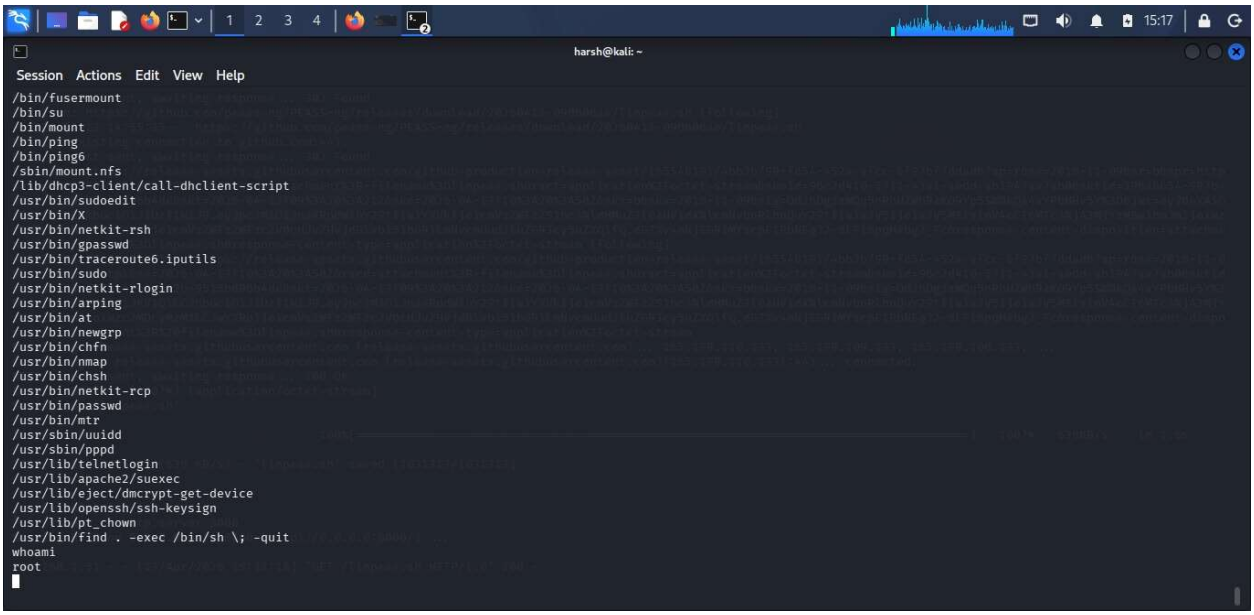

Figure 6: SUID Binary Exploitation result

3.4 Network Attack Lab

Simulated network attacks:

- ARP Spoofing using Ettercap
- Traffic interception using Wireshark

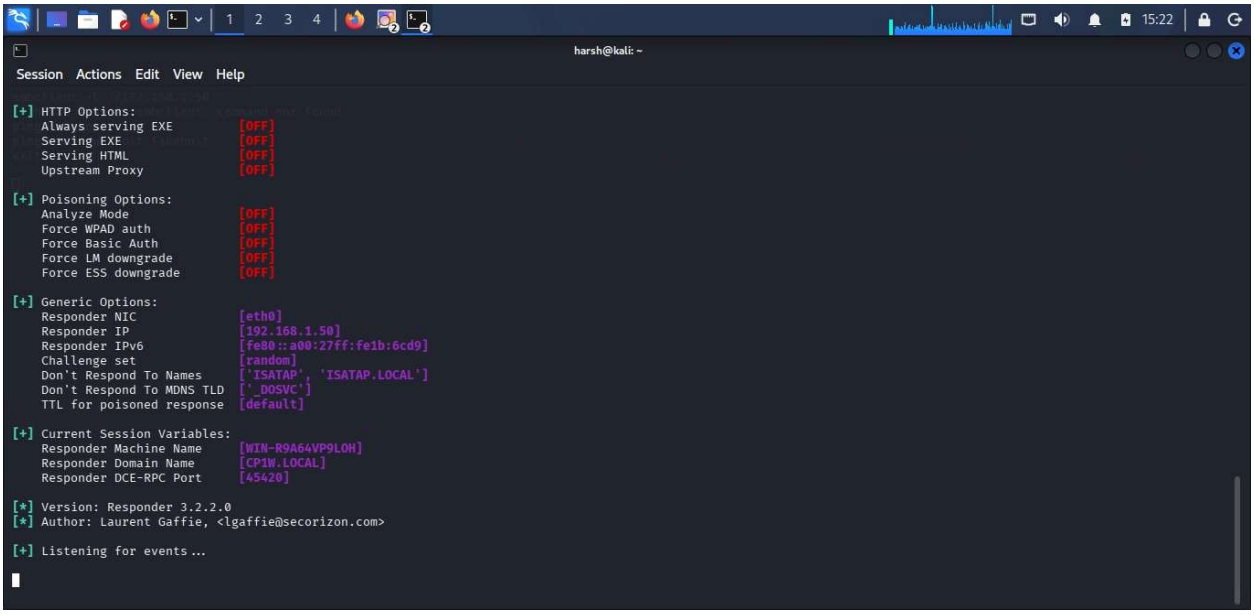

Figure 7: Responder SMB relay attack output

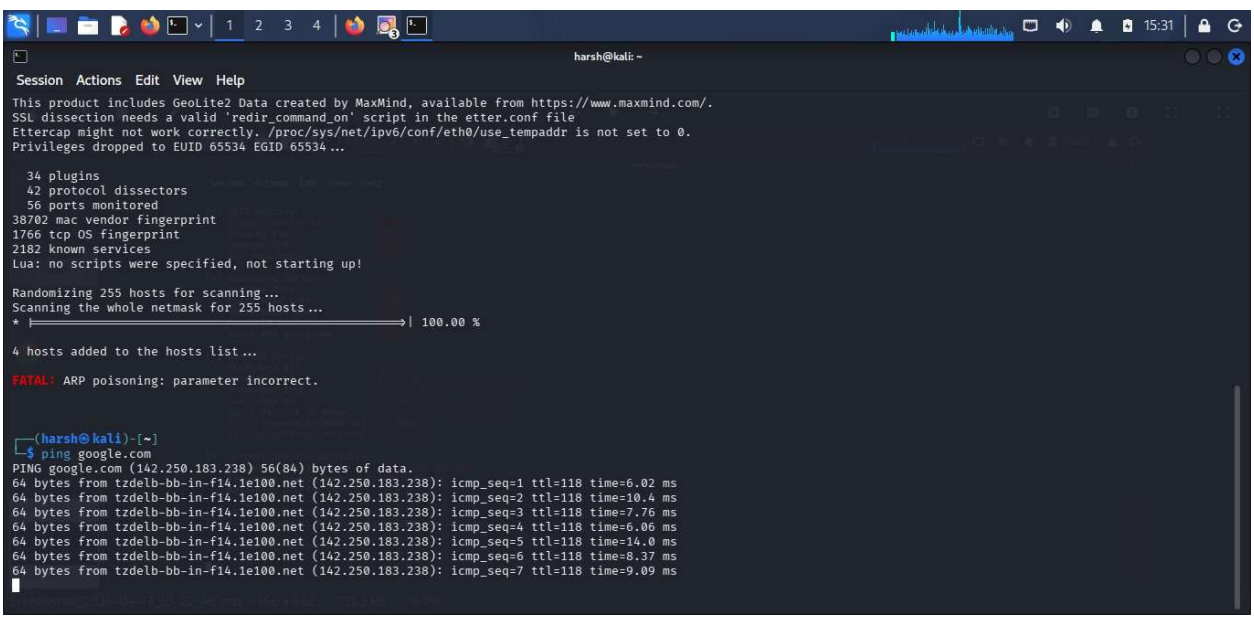

Figure 8: ARP Spoofing using ettercap

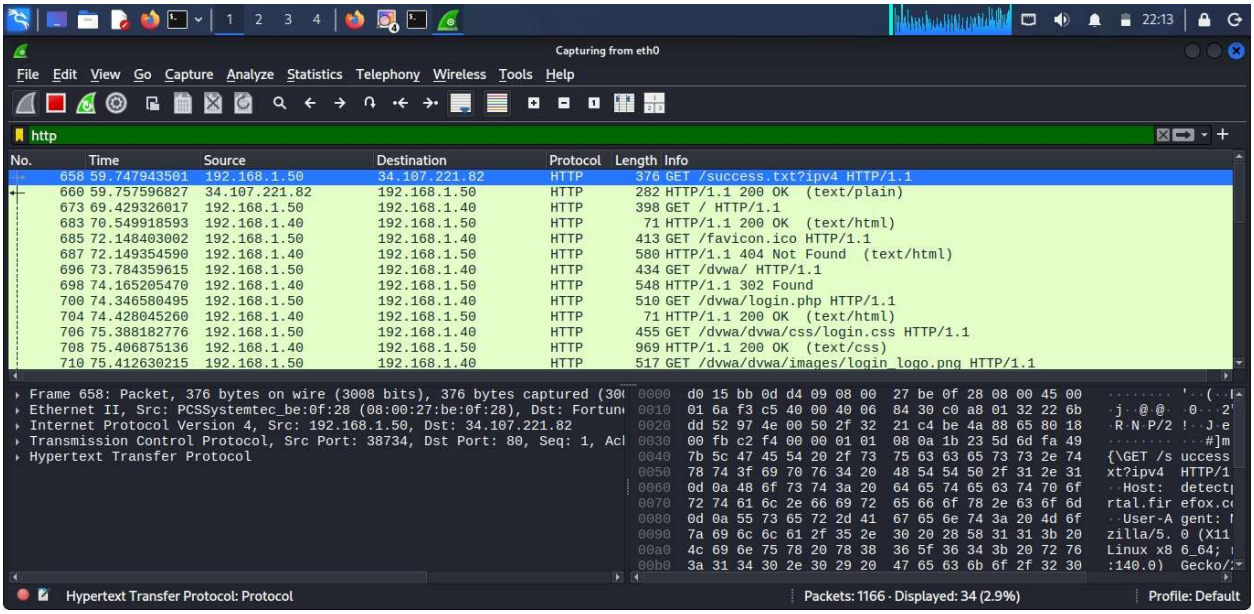

Figure 9: Wireshark captured network traffic

3.5 Mobile Application Testing Lab

Mobile apps were tested using MobSF:

- Hardcoded credentials found
- Insecure API endpoints discovered

4. TOOLS USED

Tool	Purpose
Nmap	Network scanning
Burp Suite	Web security testing
Metasploit	Exploitation framework
Wireshark	Network analysis
OWASP ZAP	Automated scanning
MobSF	Mobile security testing
Nikto	Web server scanning

5. RESULTS & FINDINGS

The following vulnerabilities were identified:

Critical

- SQL Injection
- Remote Code Execution (RCE)

High

- Cross-Site Scripting (XSS)
- Broken Authentication

Medium

- IDOR
- Security Misconfiguration

Low

- Information Disclosure

Each vulnerability was validated with proof-of-concept exploitation and assigned a CVSS score.

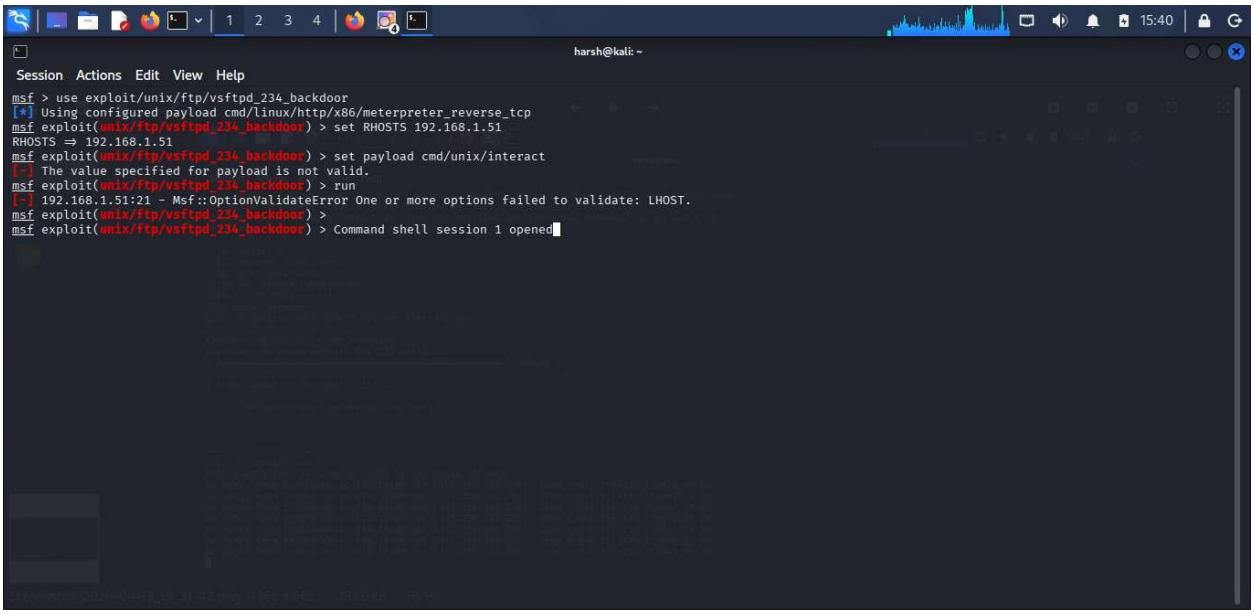

Figure 10: Metasploit Success

6. CAPSTONE PROJECT (FULL VAPT ENGAGEMENT)

6.1. Executive Summary

A complete VAPT engagement was conducted on a sample web application. Multiple vulnerabilities were identified and successfully exploited.

6.2 Attack Timeline

- Day 1: Reconnaissance and scanning
- Day 2: Vulnerability identification
- Day 3: Exploitation and privilege escalation
- Day 4: Reporting

6.3 Key Findings

- SQL Injection in login form
- XSS in search feature
- Weak password policy

6.4 Remediation Plan

- Use parameterized queries
- Implement input validation
- Enforce strong password policies
- Regular security testing

7. CONCLUSION & REFERENCES

7.1. Conclusion

The VAPT process successfully identified multiple vulnerabilities across different layers of the system. Implementing the recommended fixes will significantly improve security and reduce the risk of cyber attacks.

7.2 References

OWASP Top 10

PTES Standard Documentation

NIST Cybersecurity Framework

OWASP Testing Guide

8. APPENDIX

8.1 Appendix A: Screenshots

(All figures referenced in the report are included here for validation and evidence.)

8.2 Appendix B: Logs

B.1 Exploitation Log

Exploit ID	Description	Target IP	Status	Payload
007	XSS to RCE Chain	192.168.1.100	Success	Meterpreter

B.2 API Testing Log

Test ID	Vulnerability	Severity	Endpoint
008	BOLA	Critical	/api/users
009	GraphQL Injection	High	/graphql

B.3 Privilege Escalation Log

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.1.150	Success	Root Shell

B.4 Network Attack Log

Attack ID	Technique	Target IP	Status	Outcome
015	SMB Relay	192.168.1.200	Success	NTLM Hash

B.5 Mobile Testing Log

Test ID	Vulnerability	Severity	Target App
016	Insecure Storage	High	test.apk

8.3 Appendix C: Checklists

C.1 API Security Testing Checklist

[✓] Enumerated API endpoints

[✓] Tested BOLA vulnerabilities

[✓] Tested authentication mechanisms

[✓] Fuzzed input parameters

[✓] Checked rate limiting

C.2 Privilege Escalation Checklist

[✓] Ran LinPEAS for enumeration

[✓] Checked SUID binaries

[✓] Exploited misconfigurations

[✓] Achieved root access

[✓] Established persistence

C.3 Network Attack Checklist

[✓] Captured NTLM hashes (Responder)

[✓] Performed ARP spoofing (Ettercap)

[✓] Analyzed traffic (Wireshark)

[✓] Executed SMB relay attack

C.4 Mobile Testing Checklist

[✓] Performed static analysis (MobSF)

[✓] Conducted dynamic testing (Frida)

[✓] Tested IPC vulnerabilities (Drozer)

[✓] Identified insecure storage